

WPScan — Practical Tool Guide

WordPress detection, users/plugins/themes enumeration, vulnerability data/API token, output, proxying, and authorized credential testing.

➤ Abdullah Nasser Almsan — Personal Pentest Reference

Usage note: The project already has a WordPress cheat sheet; this guide focuses on WPScan itself and its options.

DETECT

WordPress

ENUM

u / vp / vt

VERSION

Verify

FOLLOW-UP

CVE / SearchSploit

Contents

1. Start by proving WordPress
2. Enumeration
3. Vulnerability data / API
4. Credential testing inside a lab
5. Output / troubleshooting
6. Workflow

1. Start by proving WordPress

Do not run WPScan blindly against every website.

KALI TERMINAL — Fingerprint

```
whatweb [URL]
curl -I [URL]/wp-login.php
```

KALI TERMINAL — Basic WPScan

```
wpscan --url [URL]
```

2. Enumeration

Option	Meaning
u	Users
vp	Vulnerable plugins
ap	All plugins - broader
vt	Vulnerable themes
at	All themes - broader
cb	Config backups
dbe	DB exports

KALI TERMINAL — Users

```
wpscan --url [URL] --enumerate u
```

KALI TERMINAL — Plugins/themes

```
wpscan --url [URL] --enumerate vp,vt
```

KALI TERMINAL — Broader when needed

```
wpscan --url [URL] --enumerate ap,at --plugins-detection mixed
```

Note: ap/at can generate more requests. Start with the narrowest enumeration that satisfies the lab objective.

3. Vulnerability data / API

Some vulnerability information depends on an API token.

KALI TERMINAL — Token

```
wpscan --url [URL] --api-token [TOKEN]
```

Even when WPScan reports a component vulnerability, confirm the detected version and that the exploit conditions apply.

4. Credential testing inside a lab

Note: Use only when the scenario explicitly authorizes it.

KALI TERMINAL — User + wordlist

```
wpscan --url [URL] -U [USER_OR_LIST] -P [WORDLIST]
```

Password attacks can cause lockouts or significant traffic. Use them only within the allowed lab scope.

5. Output / troubleshooting

KALI TERMINAL — Save output

```
wpscan --url [URL] -o wpscan.txt
```

KALI TERMINAL — Help / update

```
wpscan --help  
wpscan --update
```

KALI TERMINAL — Proxy through Burp

```
wpscan --url [URL] --proxy http://127.0.0.1:8080
```

A proxy can help explain WPScan requests and troubleshoot findings.

6. Workflow

Step	Action	Goal
1	Detect	Prove WordPress.
2	Base scan	Identify version/theme/interesting findings.
3	Enumerate	u / vp / vt according to the objective.
4	Version check	Confirm component and version.
5	Research	CVE/SearchSploit/Metasploit only when relevant.
6	Validate	Authorized testing only.

Prepared as a quick-reference companion to the canonical Arabic guide. Use only in labs or systems you are explicitly authorized to test.

References:

<https://github.com/wpscanteam/wpscan/wiki/WPScan-User-Documentation>

<https://github.com/wpscanteam/wpscan>